

Security Incident Report

Cloudora Security Operations | Template CLD-IR-TEMPLATE | Complete every section. If a section is empty, write why.

Report ID	CLD-IR-0002
Related ticket	CLD-0002
Report title	Payroll Phishing Campaign Resulting in Two Compromised Accounts
Analyst	Simon Agpoon
Date of report (UTC)	1:19 am
Incident severity	P1
Status	Contained
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

On August 25, 2026, Cloudora employees were targeted by a phishing campaign that pretended to be from Cloudora HR. The emails told employees that they needed to confirm their payroll information by clicking a link.

There were two versions of the phishing email. The first version spoofed the real cloudora.io email address but failed SPF, DKIM, and DMARC checks. The second version used a lookalike domain that was made to look similar to Cloudora's real domain. This second domain passed authentication because it was properly authenticated for the attacker's fake domain.

Six employees clicked on the phishing link. Two of those employees entered their passwords into the fake login page. The attacker then used the stolen credentials to sign into both accounts from an IP address located in Amsterdam, Netherlands.

The incident was reported by an employee the same morning. The two compromised accounts were contained, the attacker's access was removed, the phishing infrastructure was blocked, and the phishing emails were removed from employee mailboxes.

Four additional employees clicked the link but did not enter their credentials. Thirty employees received the phishing email but did not click it. One email that was reported at the same time was investigated and confirmed to be a legitimate Cloudora newsletter sent through Mailchimp.

Based on the available logs, there was no evidence of fraudulent payments or data theft.

2. Incident Timeline

Every significant event in order, all times in UTC. Include attacker actions, victim actions, and response actions. Cite the log source for each row - a timeline entry you cannot evidence does not belong here.

Time (UTC)	Source	Context
------------	--------	---------

Aug 25, 06:58	Msg trace	Legitimate Cloudora newsletter delivered through Mailchimp; later confirmed as a false positive
Aug 25, 08:04-08:20	Msg trace	Variant A wave 1 sent from 198.18.44.10 spoofing payroll@cloudora.io; SPF/DKIM/DMARC failed
Aug 25, 08:35-08:50	Msg trace	Variant A wave 2 sent from 198.18.44.23; Variant B sent from 198.18.51.7 using the lookalike domain
Aug 25, 08:39:03	Msg trace	seth.lane clicked Variant A but did not submit credentials
Aug 25, 08:47:12	Msg trace	freya.lynn clicked Variant A and submitted credentials
Aug 25, 09:05:44	Msg trace	ryan.boyd clicked Variant B and submitted credentials
Aug 25, 09:11	Ticket	james.holt reported the phishing email; ticket CLD-0002 created and investigation started
Aug 25, 09:58/10:12/11:47	Msg trace	hugo.marsh, chloe.price, and dina.said clicked the link but did not submit credentials
Aug 25, 10:34:20	Sign-in	Attacker accessed freya.lynn's account from 198.18.7.200 in Amsterdam
Aug 25, 13:22:05	Sign-in	Attacker accessed ryan.boyd's account from 198.18.7.200 in Amsterdam
Aug 25, ~14:00	Response	Containment actions completed on both compromised accounts

3. Findings

Finding 1 - A payroll-themed phishing campaign was sent to employees

- On 25 August, 40 Cloudora mailboxes were targeted with a phishing campaign using the subject lines "Payroll update: action required before 5pm" and "Action required: confirm your August payroll details."
- Both emails pretended to come from Cloudora HR and directed employees to cloudora-hr-portal.example, which was made to resemble cloudora.io.
- Exchange Online Protection quarantined every copy sent to four recipients. The remaining 36 recipients had at least one copy delivered to their inboxes.
- Evidence: CloudoraMsgTrace_CL delivery events and the reported .eml files.

Finding 2 - The attacker used two different authentication methods, and passing authentication did not make the email legitimate

- Variant A spoofed the legitimate payroll@cloudora.io address and failed SPF, DKIM, and DMARC authentication checks (compauth=fail). It was sent from 198.18.44.10 and 198.18.44.23.
- Variant B was sent using the attacker's own lookalike domain, cloudora-hr-portal.example, from 198.18.51.7. This message passed SPF, DKIM, and DMARC, but only for the fake domain and not for Cloudora's actual domain.
- Authentication only confirms that a message is authorized for the sending domain. It does not prove that the domain itself is legitimate. Both variants were malicious.
- This same authentication concept was also used when determining that the reported newsletter was a false positive in Finding 6.

Finding 3 - Two employee accounts submitted credentials and were compromised

- freya.lynn@cloudora.io and ryan.boyd@cloudora.io both clicked on the phishing links and submitted their credentials. CloudoraMsgTrace_CL recorded the clicks at 08:47 and 09:05, with CredentialsSubmitted = Yes.
- Both accounts were later accessed from 198.18.7.200 in Amsterdam, Netherlands, using a Windows 11 / Chrome device that had not previously been associated with either account.
- Freya's account was accessed at 10:34, which was an impossible-travel event compared with her legitimate Manchester sign-ins earlier that morning. Ryan's account was accessed at 13:22.
- The attacker accessed Outlook Web for both accounts and also accessed SharePoint Online for Freya.
- This confirms that the attacker used valid credentials obtained through the phishing campaign (T1078).

Finding 4 - Four additional employees clicked the link but did not submit credentials

- seth.lane, chloe.price, hugo.marsh, and dina.said clicked the phishing link but did not submit credentials (CredentialsSubmitted = No).
- There were also no unusual sign-ins associated with their accounts in the available logs. They are therefore not confirmed to be compromised.
- However, because they reached the credential-harvesting page, they are considered elevated-risk users. As a precaution, they should reset their passwords and receive a direct follow-up from the security team.

Finding 5 - Thirty employees received the phishing email but did not click it; four were protected by EOP

- **Thirty employees received the phishing message but did not click the link. These users make up the near miss group and should receive follow-up communication.**
- **Four additional employees, emma.hayes, maya.chen, nina.cole, and ruth.dean, were targeted but had every copy of the phishing message quarantined by Exchange Online Protection. These employees never received the message in their inboxes.**
- **Separating employees into these different groups makes the response more appropriate for each level of exposure.**

Finding 6 - The reported Mailchimp newsletter was legitimate and was cleared as a false positive

- **The "Cloudora Monthly" newsletter forwarded by adam.clark was legitimately sent for Cloudora through Mailchimp.**
- **The message passed SPF, was DKIM-signed and aligned with cloudora.io, and passed DMARC. It also included a valid one-click List-Unsubscribe option and only linked to Cloudora's legitimate list-manage domain.**
- **Unlike variant B, the newsletter's authentication was aligned with the real cloudora.io domain.**
- **Verdict: Legitimate marketing email and not part of the phishing attack. The message was cleared using the available evidence so it does not need to be investigated again.**

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
Domain	Cloudora-hr-portal.example	25 Aug 2026, approximately 08:04	Lookalike of the legitimate cloudora.io domain. Used for phishing delivery, credential-harvesting links, Reply-To addresses and campaign infrastructure. Block the domain and all subdomains.
URL	hxxps://cloudora-hrportal[.]example/payroll/login	25 Aug 2026, 08:04	Credential-harvesting link used by phishing variant A. The URL is defanged for safe reporting.
URL	hxxps://login.cloudora-hrportal[.]example/verify	25 Aug 2026, 08:36	Credential-harvesting link used by phishing variant B. Ryan Boyd submitted credentials through this variant.
IPv4 address	198.18.44.10	25 Aug 2026, 08:04	Variant A first-wave sending relay and phishing infrastructure. Sent messages spoofing payroll@cloudora.io; SPF, DKIM and DMARC failed.

IPv4 address	198.18.44.23	25 Aug 2026, 08:39	Variant A second-wave sending relay in the same /24 range as 198.18.44.10. Used to send the phishing email reported by James Holt.
IPv4 address	198.18.51.7	25 Aug 2026, 08:36	Variant B sending relay. Authentication passed for the attacker-controlled lookalike domain, not for the genuine Cloudora domain.
IPv4 address	198.18.7.200	25 Aug 2026, 10:34:20	Attacker sign-in IP located in Amsterdam in the training data. Used to access Freya Lynn's and Ryan Boyd's accounts with harvested credentials.
Sender address	payroll@cloudora.io — spoofed	25 Aug 2026, 08:04	Forged sender used by variant A. The message claimed to originate from Cloudora, but authentication failed and the actual sending infrastructure was external.
Reply-To address	hr-support@cloudora-hrportal.example	25 Aug 2026, 08:04	External attacker-controlled Reply-To used by variant A. Replies would leave Cloudora and be delivered to the lookalike domain.

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
Initial Access	T1566.002	Phishing: Spearphishing Link	Findings 1-2; phishing emails and links
Credential Access	T1598.003	Phishing for Information: Spearphishing Link	The credential-harvesting page accessed through the phishing link
Initial Access	T1078.004	Valid Accounts: Cloud Accounts	Finding 3, based on attacker sign-ins using harvested credentials
Infrastructure	T1583.001	Acquire Infrastructure: Domains	Lookalike domain used by attacker

--	--	--	--

6. Scope

Accounts confirmed compromised

- freya.lynn@cloudora.io, with attacker sign-in at 10:34:20 UTC, and ryan.boyd@cloudora.io, with attacker sign-in at 13:22:05 UTC, both on 25 Aug.
- Both accounts were accessed from 198.18.7.200 and both users submitted their credentials to the phishing page.

Accounts targeted but not breached

- seth.lane, chloe.price, hugo.marsh, and dina.said clicked the phishing link but did not submit credentials.
- No unusual sign-ins were found for these accounts. A precautionary password reset and direct check-in are recommended.

Accounts investigated and cleared (false positives)

- Thirty employees received the phishing email but did not click it and are classified as the near-miss group for user communication.
- Four additional employees, emma.hayes, maya.chen, nina.cole, and ruth.dean, had every copy of the phishing email quarantined by EOP.

7. Actions taken

What was actually done, by whom, at what time (UTC), in order. Containment first (stop the bleeding), then eradication (remove attacker access and persistence), then verification (prove it worked). An action without a timestamp did not happen.

Order	Action	Why
1	Revoked active sessions and refresh tokens for freya.lynn and ryan.boyd	Immediately removed the attacker's active sessions
2	Reset passwords for both compromised accounts	New passwords are effective after stolen sessions are terminated
3	Required and re-registered MFA	Prevents stolen passwords from being enough for future access

4	Blocked 198.18.44.10, 198.18.44.23, 198.18.51.7, 198.18.7.200, and cloudora-hr-portal.example	Stops the attacker from sending, hosting, or accessing the phishing infrastructure
5	Removed phishing emails from all mailboxes	Prevents other employees from clicking remaining copies
6	Re-ran sign-in and attacker-IP queries	Confirmed there was no 198.18.7.200 activity after containment
7	Phishing remediation training assigned to users that clicked on the link	Ensures affected users receive follow-up training to reduce the risk of future phishing clicks.

8. Recommendations

Quick Wins

- Reset passwords for the four users who clicked the phishing emails.
- Block the phishing domain and attacker IP addresses across email and web security tools.
- Make the phishing report button easy for employees to find and use.
- Send a short reminder to employees about checking links and reporting suspicious emails.

Strategic Changes

- Require MFA for all employees and disable older authentication methods that only use passwords.
- Set Cloudora's DMARC policy to reject to better prevent domain spoofing.
- Add detection for suspicious lookalike domains that imitate Cloudora.
- Create alerts for unusual foreign logins shortly after a user clicks a phishing link.

9. Lessons learned

- Employee reporting helped the security team find the attack before it caused more damage.
- Message tracing made it easier to identify the full phishing campaign and affected users.
- Checking the attacker's IP address helped uncover the second compromised account.
- Passing email authentication does not always mean a message is legitimate.
- Connecting phishing clicks with unusual logins could help detect similar attacks faster.